Login and Account Management — Requirements Specification

This document describes the functional requirements for the login and account management module of a web application. It covers authentication, registration, password management, account security, and session handling. It is a synthetic example used for demos and evaluation.

1. Authentication

REQ-LA-01: Email and password login

The system shall allow a registered user to log in using their email address and password.

REQ-LA-02: Account lockout after failed login attempts

The system shall lock a user's account for 15 minutes after 5 consecutive failed login attempts within a 10-minute window.

REQ-LA-03: Locked-account message

When an account is locked, the system shall show a message stating that the account is temporarily locked and the time at which the user may try again.

REQ-LA-04: Generic error message for invalid credentials

The system shall display a generic "invalid email or password" error message when login fails, without indicating whether the email address or the password was incorrect.

REQ-LA-05: Remember me

The system shall offer a "Remember me" option that keeps the user logged in on that device for 30 days.

2. Account Registration

REQ-LA-06: Required registration fields

The system shall require a valid email address, a password, and the user's full name to create a new account.

REQ-LA-07: Email verification

The system shall keep a new account unverified until the user clicks the confirmation link in the verification email sent to the address provided at registration.

REQ-LA-08: Duplicate email prevention

The system shall reject a registration that uses an email address already associated with an existing account, and direct the user to log in or reset their password instead.

REQ-LA-09: Easy registration

Registration should be quick and easy for new users.

3. Password Management

REQ-LA-10: Password complexity

The system shall require new passwords to be at least 12 characters long and to contain at least one digit and one symbol.

REQ-LA-11: Password reset and session invalidation

The system shall send a password reset link to the user's registered email address on request, and shall end all of the user's other active sessions when the password is changed.

REQ-LA-12: Reset link expiry

A password reset link shall expire 24 hours after it is sent.

REQ-LA-13: Password reuse

The system shall prevent a user from reusing any of their 3 most recent passwords.

4. Account Security

REQ-LA-14: Two-factor authentication

The system shall allow a user to enable two-factor authentication (2FA) using a time-based one-time password (TOTP) authenticator app.

REQ-LA-15: Protection against common attacks

The system should be secure against common attacks.

REQ-LA-16: Login audit log

The system shall record every successful and failed login attempt in an audit log with the timestamp, the email address used, and the source IP address.

5. Session Management

REQ-LA-17: Session timeout

User sessions should time out after a reasonable period of inactivity.